

작업 기록 (이해용) — 서비스 고도화 및 정식 배포 (v3.4)

- 작성일: 2026년 8월 4일 · 작성: 최혜윤(기획·PO 총괄) · rachel@hive-mind.kr
- 용도: 학습·구두 설명 대비 내부 상세본 (무엇·왜·어떻게 포함, 대외 공유 아님)
- 품질 기준: 정산 정확도 불변식(431,296행 · 완전매칭 99.50% · 원본 대사 검증 86건) 전 과정 유지

1. 파일럿 · 취약점 조치

- 무엇: 라이브 앱에 계약사·운영자 페르소나 에이전트 + 아키텍처 리뷰 투입, 실 API 기반으로 사용 마찰·보안 취약점 발굴
- 결과: 취약점 발견·조치 완료(검증)

취약점	조치
초대로 운영사 최고관리자 무승인 발급	초대는 계약사 계정 전용, 운영사는 가입 후 승인
동의가 화면뿐, 미동의자도 전체 정산 조회	동의·온보딩 서버 강제(미완료 계약사 데이터 API 403)
명세서 요율이 전 테넌트에서 매칭	테넌트 스코프로 제한
조회전용 담당자가 유통사율 저장	관리 권한 필요로 상향

- 하드닝: 마스터 원자적 쓰기 · 비밀번호 8자 통일 · 계약 버튼 권한 게이팅

설명 — 화면만으로는 드러나지 않는 실사용·보안 문제를 실제 계정으로 뚫어보고 사전 차단. 외부 계약사 오픈 전 최소 안전선 확보 단계임.

2. 저장소 이전 — SQLite

- 무엇: 마스터(출판사·계약·회원·초대·플래그·별칭 등)를 JSON 파일 → SQLite(WAL) 이전
- 어떻게: 문서·블롭 저장소(컬렉션 단위 트랜잭션 교체), 최초 기동 시 JSON 1회 자동 이관, load/save 시그니처 유지(호출부 무변경)
- 검증: 이관(출판사 128 등)·라운드트립·회귀 유지

설명 — JSON은 ① 재시작 시 소멸 ② 동시 쓰기 clobber ③ 크래시 시 빈 파일화 위험이 있었고, 파일럿 중 계약 4→0 소멸이 실측됐음. 저장소를 통째로 바꾸되 load/save 시그니처를 보존해 호출부는 한 줄도 안 바꿨음.

3. 정산 마감 / 원장

- 무엇: 월 지급액을 확정=불변 스냅샷으로 고정(초안→확정→지급), 선인세(MG) 이월 원장 관리
- 검증: 런1 MG 5천만 상계→지급 21,990,569 / 확정 후 런2 MG 이월(상계0)→70,340,569, 이중 차감 없음

설명 — 지급 근거는 특정 시점에 확정되어 변하지 않아야 함(재현·감사). MG는 여러 달에 걸쳐 회수되므로 지난 달 회수액을 원장에 기록해 다음 달이 잔액만 상계하도록 해 이중 차감을 막았음.

4. 회사 정보 자가 관리 · 삭제

- 무엇: 계약사가 사업자번호·대표자·주소·정산 입금계좌·세금계산서 이메일을 자가 입력
- 결과: 회원·출판사 삭제(자사만 수정, 마지막 최고관리자·본인 삭제 방지)

설명 — 정산 SaaS에 필수인 지급·세무 정보를 계약사가 직접 관리하게 하고, 잘못 만든 계정 정리 기능을 붙였음.

5. 성과 분석

- 무엇: 월별 추세·전월 대비(MoM)·유통사 성과·상위 작가/작품 파레토·집중도·유통대행 비중
- 스코프: 계약사 자사 / 운영자 전체

설명 — "지난달 대비 왜 늘고 줄었나"에 답하는 화면. 돈을 내는 주체가 출판사이므로 출판사 편의를 우선했음.

6. 운영 자동화

- 수집 현황판: 유통사 31곳 × 월 매트릭스(검증/미검증/미수신)
- 이상 탐지: 전월 대비 급변 $\pm 40\%$ ·유통사 누락·음수·합계 불일치·파싱 오류
- 마감 스케줄러: 출판사별 마감 현황, 마감일·대상월·리마인더, 백그라운드 감사 리마인더

설명 — 운영 병목(수집 추적·품질 검증·마감 누락)을 시스템이 대신 감시. 외부 시스템 접근 없이 수집된 데이터만으로 구현했고, 유통사 자동 수집(RPA)은 접근 수단이 필요해 분리했음.

7. 정식 배포 — Railway 영속 볼륨

- 무엇: 상태(SQLite·세션·계약 첨부)를 영속 볼륨에 저장, 재배포에도 계정·데이터 보존
- 어떻게: 볼륨 마운트에 DB·첨부 경로 고정, 환경변수 분리(세션 시크릿·DB 경로·첨부 경로·API 키), 시크릿 코드·저장소 미포함
- 결과: 최초 시드(운영사·정산 431,296행·출판사 128·계약사 데모 1), URL 상시 운영, 재배포 후 데이터·세션 유지 확인

설명 — 컨테이너 기본 파일시스템은 재배포마다 초기화되므로 DB가 볼륨 위에 없으면 매 배포마다 데이터가 사라짐. 세션 시크릿을 고정값으로 분리해 재배포 후에도 로그인 세션이 유지됨.

8. 접속 게이트 분리 · 계약사 자체 계약 관리

- 무엇: 운영사=회원가입 후 승인 / 계약사=초대 링크 발급(초대는 계약사 전용). 출판사관리자가 자사 계약·정산 마감을 직접 관리(담당자는 조회 전용)
- 어떻게: 신설 권한 `contracts:manage_own`, 계약·마감 쓰기 10개 지점에 자사 스코프 강제(require는 OR, 전사 마감 현황엔 미포함)
- 검증(라이브 6종): 자사 생성/삭제 200 · 타사 생성/수정/삭제 403 · 전사 마감현황 403 · 운영자 전 테넌트 유지

설명 — 계약 당사자는 출판사이므로 자사 계약·정산은 출판사가 스스로 관리(셀프서비스)함. 권한만 열면 파라미터의 출판사 ID를 바꿔 타사 계약을 만들 수 있어, 쓰기 지점 전부에 소속 검사를 추가했음. 권한 검사가 OR로 동작하는 점을 이용해 전사 마감 현황에는 자사 권한을 포함하지 않아 타사 마감 상태 노출을 차단했음.

9. 운영자 콘솔 홈 재편

- 무엇: 정산 요약 홈에 고객사(출판사)별 정산 1차 블록 신설(행 클릭 시 해당 고객사 화면 이동), 유통사별·상위 작가 2차 배치. 운영자 역할 토크 라벨을 "운영자 콘솔 / 고객사 화면"으로 명확화

설명 — 운영사의 고객은 128개 출판사이므로 첫 화면을 고객사별로 재편했음. 반면 계약사 워크스페이스는 "내 정산이 리디·카카오별로 얼마"가 핵심이라 유통사 중심을 유지 — 같은 화면이라도 보는 주체에 따라 우선 축이 다름.

10. 브랜드 · UI

- 무엇: 브랜드 심볼(금색 hexa) 로고 전면 적용, 로그인 화면 개편(다크), 내부 화면 라이트 유지

설명 — 첫인상·브랜드 정합은 강화하되, 업무 화면은 장시간 사용을 고려해 라이트로 유지했음.

11. 세무 · 지급 연동 (검토)

- 원천징수 지급명세서·전자세금계산서: 팝빌(링크허브)·바로빌·더존 API로 구현 가능
- 계좌 실명 확인·대량 이체: 오픈뱅킹/펌뱅킹
- 사업자 인증·파트너 계약 선행 → 파트너 결정 후 착수

설명 — 기술적으로는 신뢰처 API로 가능하나, 사업자 인증·계약이 선행 조건이라 파트너 확정 후 진행함.

12. 남은 과제 · 로드맵

- 🟡 정식 오픈 전: 로그인 시도 제한(레이트리밋) · SMTP(초대·알림 메일 실발송)
- 🟡 후속: 작가 마스터+명세서 자동 배포(SMTP 후) · 세무 연동(파트너 후) · 자동 마감 생성(정산 데이터 영속화 후) · 페이지네이션·계약 일괄 편집 · 공개 API/웹훅
- 참고: Railway 영속 볼륨(기존 최우선 인프라 과제)은 완료